DAY 28 Assignment — SQL INJECTION

PART A — FUNDAMENTALS

1. What is SQL?
SQL stands for Structured Query Language. It is used to communicate with and manage relational databases.

2. What is SQL Injection?
It is a security vulnerability where attacker insert malicious input into SQL queries.

3. What is a WHERE clause?
WHERE clause is used in SQL to detect based on database records on specific conditions. It only records when condition is matched.

4. Explain AND and OR in SQL conditions.
AND: returns TRUE only when all specified conditions are true.
OR: returns True even if one specified condition is true.

5. Why is 1=1 considered an always-true condition?
Because both sides of the comparison have the same value.

6. What is SQL comment syntax used for conceptually?
SQL comments are used to make database ignore certain part of query. More likely for developers to add notes or explanation without executing them as SQL instruction.

7. Explain why raw user input should not be concatenated directly into SQL queries.
Attackers may manipulate the input so it changes structured query structure. This leads to unauthorized connection and SQL injection.

8. What is a parameterized query?
It uses placeholders for user-provided values. It separates SQL query instruction from user to help prevent SQL instruction.

9. What is a prepared statement?
It is a SQL statement prepared with placeholders for input values. Values are supplied separately when statement is executed.

10. Why does Least Privilege matter for database accounts?
Database accounts should receive only the minimum permissions required to perform their tasks.

PART B — PORTSWIGGER LAB

Complete the assigned PortSwigger Web Security Academy lab:

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Answer:

1. Which parameter was vulnerable: category

DAY 28 Assignment — SQL INJECTION

2. What product category did you initially select: Gift

3. What was the purpose of the released = 1 condition?
It ensures only product marked as released are displayed.

4. What controlled training input changed the query behaviour: 'OR 1=1 --

5. What does the 1=1 condition mean: True always, on both sides.

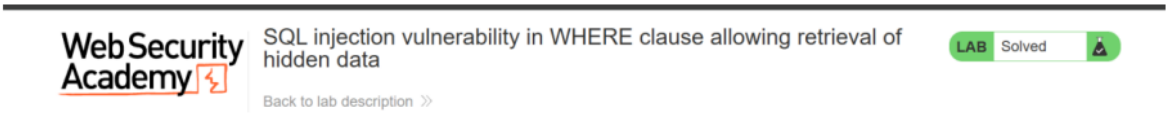
6. Why did additional/unreleased products become visible?
The injected OR 1=1 condition changed the SQL query logic. Therefore the condition is always true and the -- comments out the remaining SQL condition, the application returned products that were supposed to remain hidden.

7. Which Burp Suite feature did you use to resend the request: Burp Suite Repeater

8. What changed between the original response and modified training response?
The original response displayed products belonging to the selected Gifts category. The modified response returned additional products, including unreleased products.

9. Did PortSwigger mark the lab as Solved: YES

10. Include one screenshot showing successful lab completion.



PART C — DEFENSIVE ANALYSIS

Fictional insecure design:

User Input
↓
Raw String Concatenation
↓
SQL Query
↓
Database

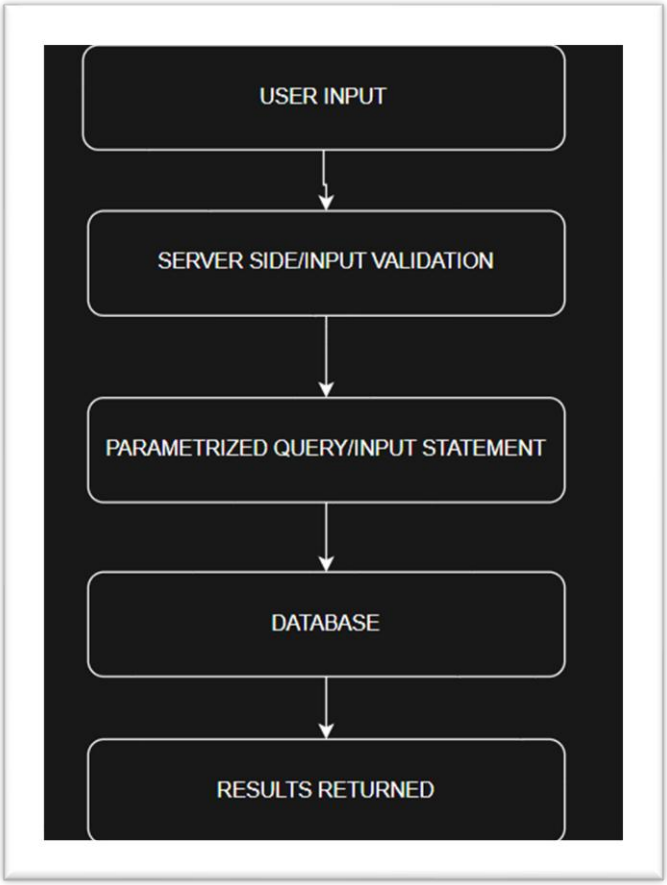
Answer:

1. What is wrong with this design?

- User input is directly attached with SQL query instruction
- Attacker can manipulate the query through SQL injection

2. Rewrite the workflow conceptually using a parameterized query.

DAY 28 Assignment — SQL INJECTION



3. Why should input also be validated server-side?
Clinet-side validation can be modified or bypassed. Server side validation ensures backend check the expected format and rules.

4. Why should the database account use Least Privilege?
The database account should only have permission required by the application. Limiting the damage if the account is compromised.

5. Why should detailed database errors not be exposed publicly?
Detailed errors may reveal database structure, table names, queries or internal system information.

PART D — SHORT REFLECTION

What did this lab teach you about the difference between user DATA and SQL QUERY STRUCTURE?

- The user data and SQL query structure must be kept separate.
- User data refers to the values entered by users, such as search terms / category names.
- SQL query structure contains the actual instructions that tell the database what information to retrieve.
- During the lab, I used the input ' OR 1=1-- to demonstrate how user input could change the intended SQL query logic.

- This happened because the application treated the input as part of the SQL instruction instead of just data.
- I learned that parameterized queries and prepared statements help prevent this by keeping user input separate from SQL commands.